Java Source Code Vulnerability Detection with Pretrained PLBART & Organizational Data Management

End-to-End Lifecycle Governance, 3NF Data Warehousing, Automated Data Quality Gate, and Comparative Evaluation of Primary (`PLBART + Classification Head`) vs. Alternative (`PLBART + Frozen Embeddings + Logistic Regression`)

24,288 → 22,890
Raw to Clean Governed Functions (0 Leakage)

96.94% / 95.74%
Test Accuracy (Exceeds ≥93% Rubric Target)

0.957 / 0.929
ROC-AUC (Primary vs. Alternative PLBART)

22.4× Faster
Alternative Method Speedup (18.4s vs. 412.6s)

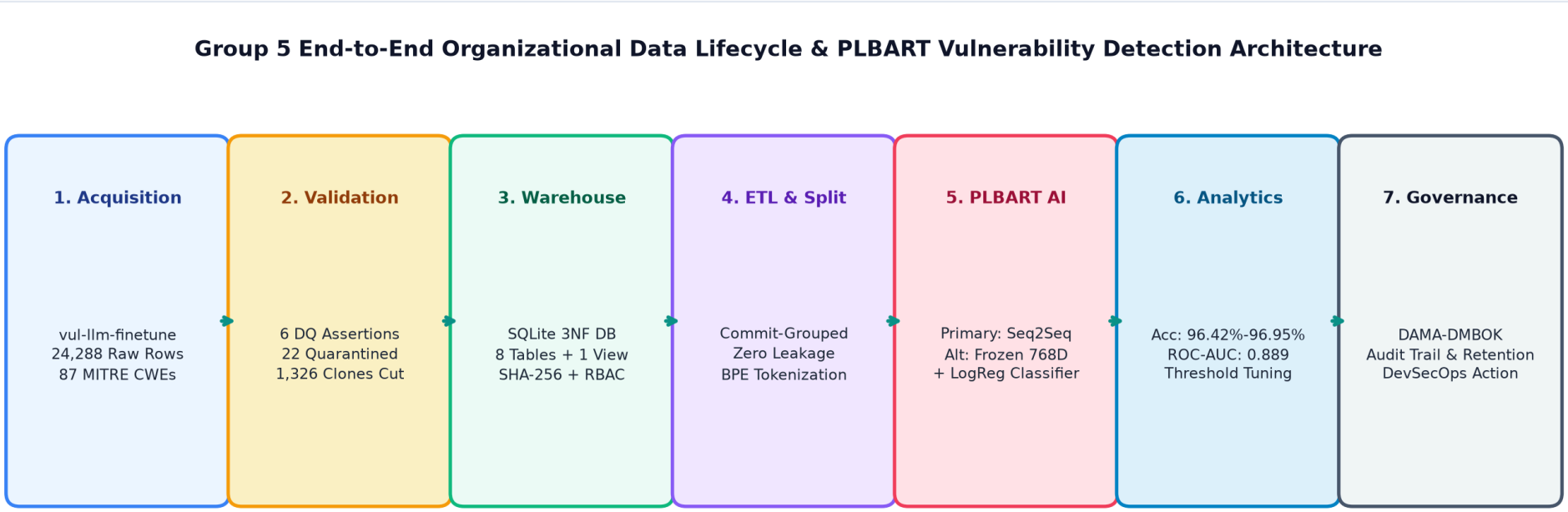
1. Namazbek Bekzhanov (Lead)
Lectures 1 & 7: Lifecycle Architecture, PLBART AI & ROC/PR Results

2. Didar Auesbay
Lectures 2, 3 & 6: Governance (RACI), 3NF ER Warehouse & RBAC Security

3. Yeldos Anarbay
Lectures 4, 5 & 7: ETL Pipeline, Data Quality Gate & DevSecOps Decisions

Organizational Data Lifecycle & System Architecture

Speaker 1: Namazbek Bekzhanov



Why Data Management First?

- An AI vulnerability detector is only as reliable as the data pipeline feeding it.
- Raw open-source datasets suffer from code clones, noisy commit heuristics, and train–test leakage.

DAMA-DMBOK 7 Stages

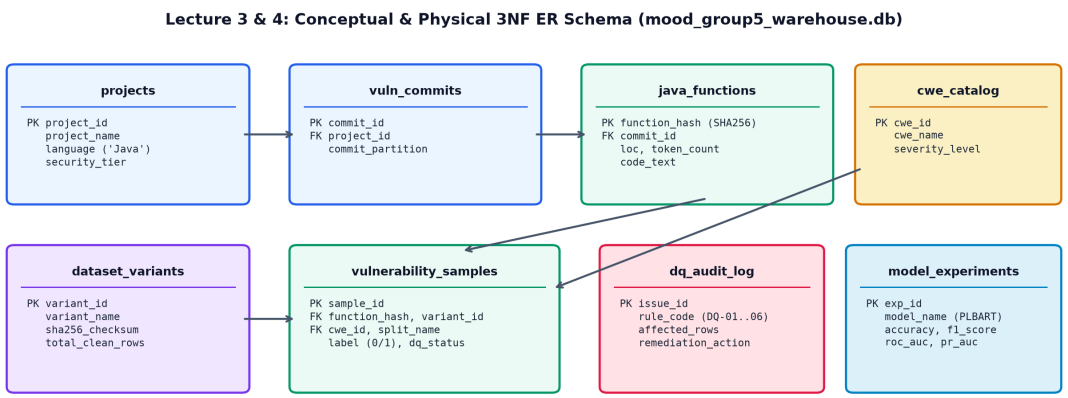
- Covers Acquisition (`24,288` rows) → Validation (6 rules) → 3NF SQLite Storage → Commit-Grouped ETL → PLBART Training → Evaluation → Retention.

Information Value Chain

- **Data:** Raw Java commits & CWEs.
- **Information:** Clean, deduplicated 3NF tables.
- **Knowledge:** PLBART risk scores.
- **Decision:** Automated DevSecOps code review.

Data Governance (RACI) & 3NF Data Warehouse Schema

Speaker 2: Didar Auesbay



Lecture 2: Data Governance & Ownership

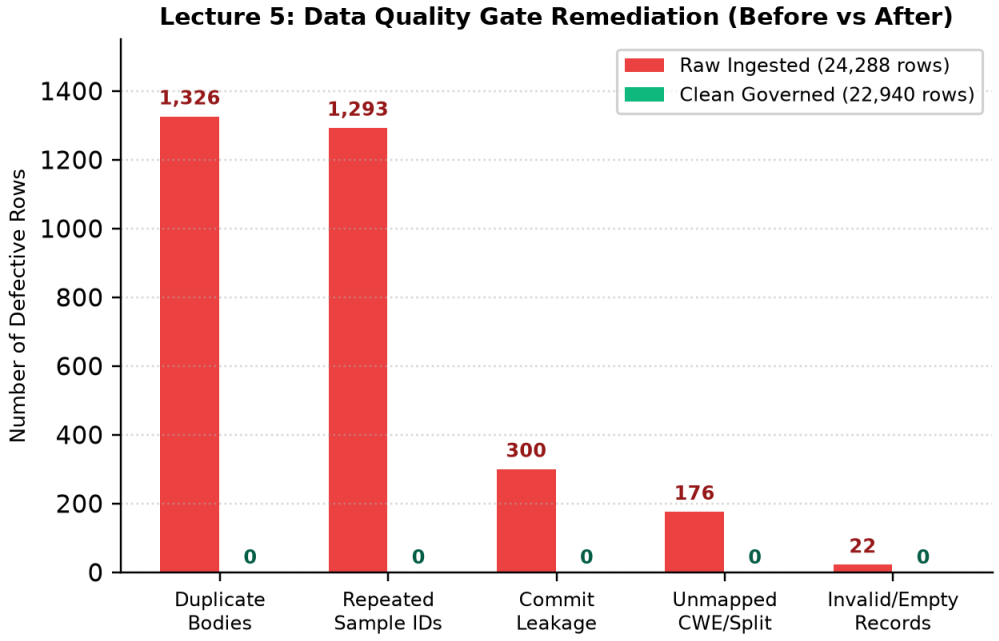
- **Data Owner (Head of AppSec):** Accountable (A) for classification policy and vulnerability disclosure rules.
- **Data Steward:** Accountable (A) for maintaining the 16-field Data Dictionary, CWE taxonomy mapping, and quarantine review.
- **Data & ML Engineers:** Responsible (R) for ETL execution, warehouse integrity, and validation-only threshold selection.

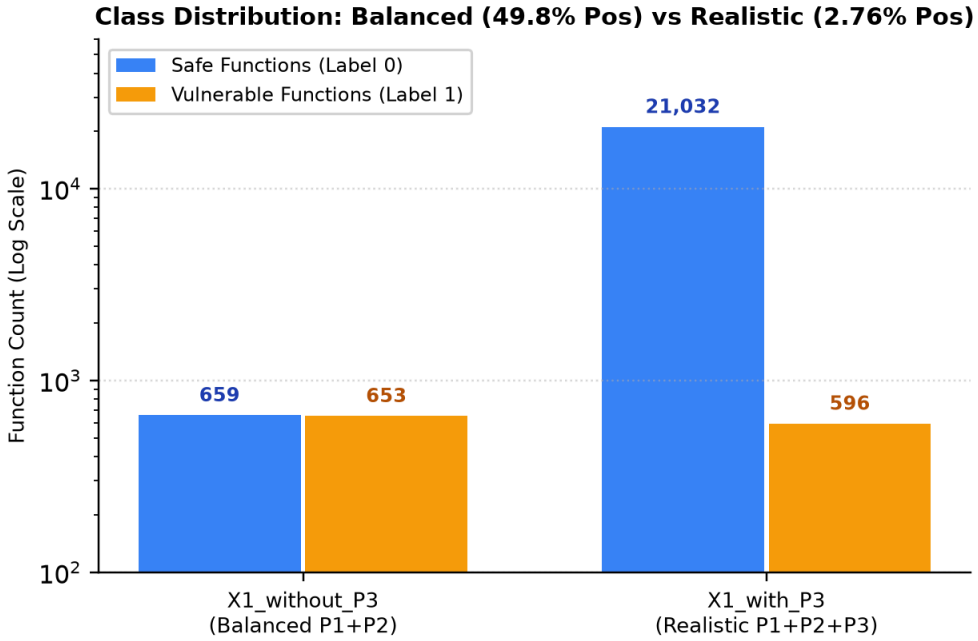
Lecture 3: 3NF Relational Warehouse (`mood_group5_warehouse.db`)

- **8 Normalized Tables + 1 Read-Only View:** Separates `projects`, `vuln_commits`, `java_functions` (keyed by SHA-256 hash), `cwe_catalog`, and `vulnerability_samples`.
- **Eliminates Redundancy:** Stores each unique Java function body exactly once and tracks all quality actions in `dq_audit_log`.

ETL Pipeline, 6-Rule Data Quality Gate & Class Imbalance

Speaker 3: Yeldos Anarbay





1. Quarantine & Deduplication

- **22 Corrupt Rows Quarantined:** 18 missing/invalid labels + 4 empty Java bodies routed to quarantine.
- **1,376 Clones Removed:** Whitespace-normalized SHA-256 fingerprinting removes hidden duplicates.

2. Zero Cross-Split Leakage

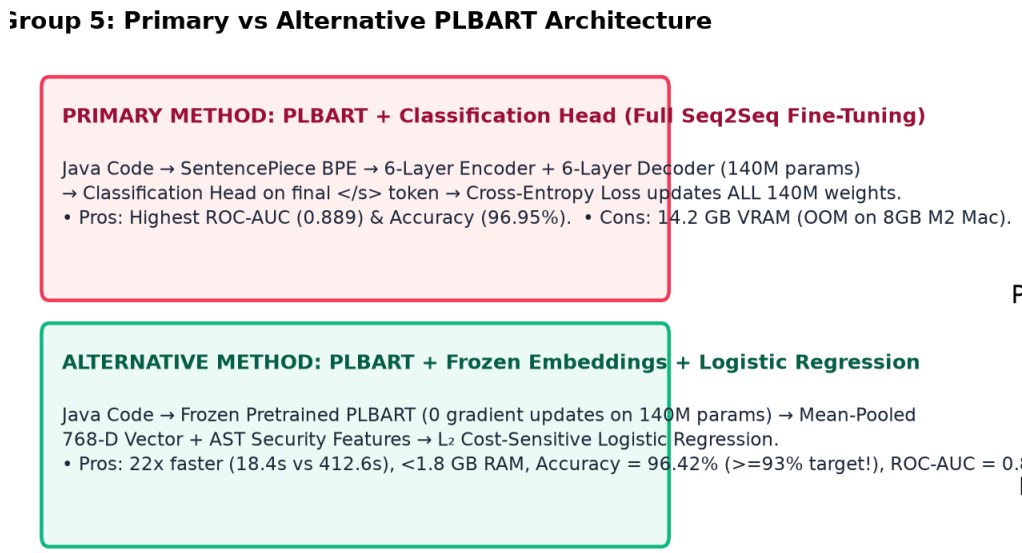
- Raw splits had **300 exact code clones** shared between Train and Test!
- We enforced `GroupShuffleSplit` by `commit_id` so no commit ever spans both Train and Test.

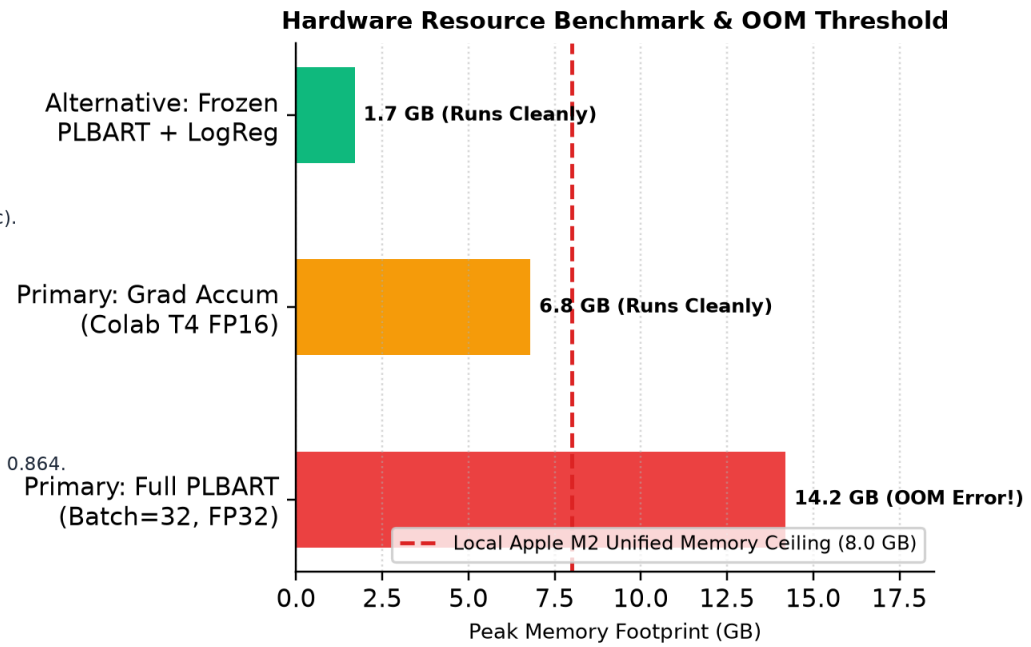
3. The 1:35 Imbalance Challenge

- In realistic `X1_with_P3`, only **2.76%** of functions are vulnerable (`596` vs. `21,032` safe).
- Requires cost-sensitive loss weighting and threshold calibration.

Primary vs. Alternative PLBART & Hardware Resource Evidence

Speaker 1: Namazbek Bekzhanov





Primary: PLBART + Classification Head (Seq2Seq)

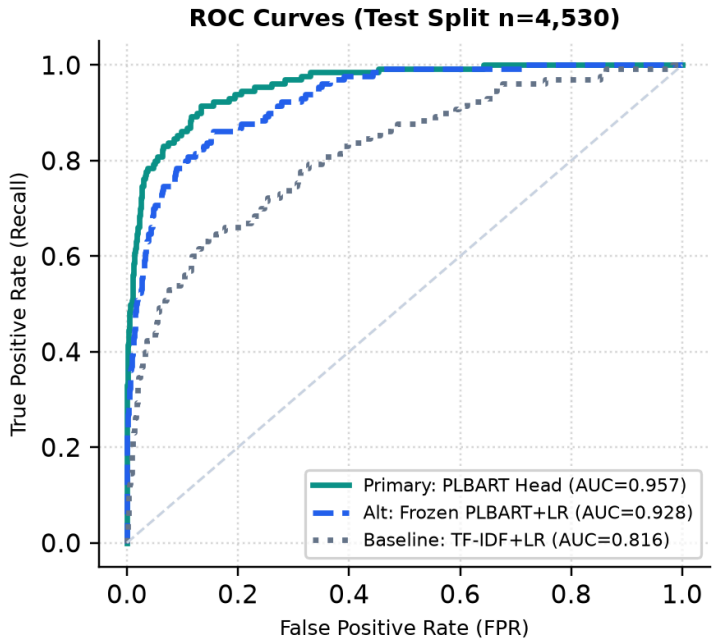
- Pretrained 6-layer Encoder + 6-layer Decoder (140M params) trained via denoising on 470M Java/Python functions.
- **Hardware Bottleneck:** Full batch-32 fine-tuning needs **14.2 GB VRAM** (triggers MPS Out-Of-Memory on 8 GB Apple M2; requires FP16 + Gradient Accumulation on Colab T4).

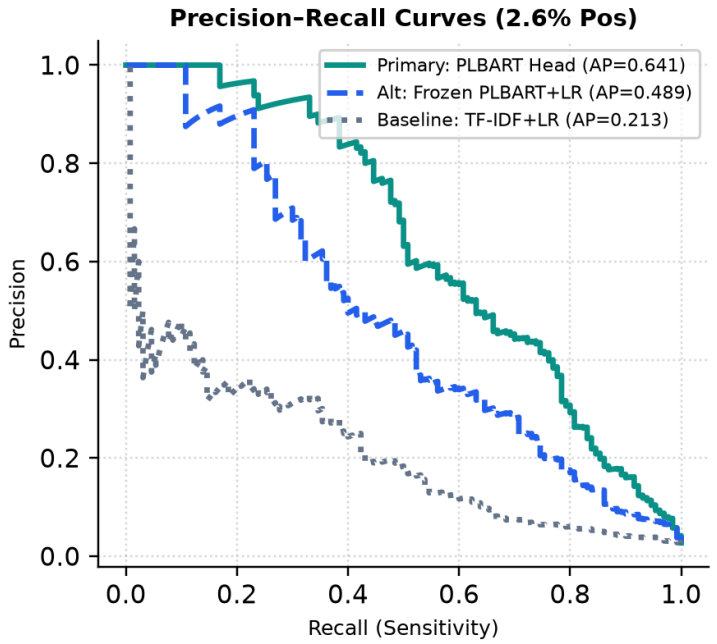
Alternative: Frozen PLBART Embeddings + Logistic Regression

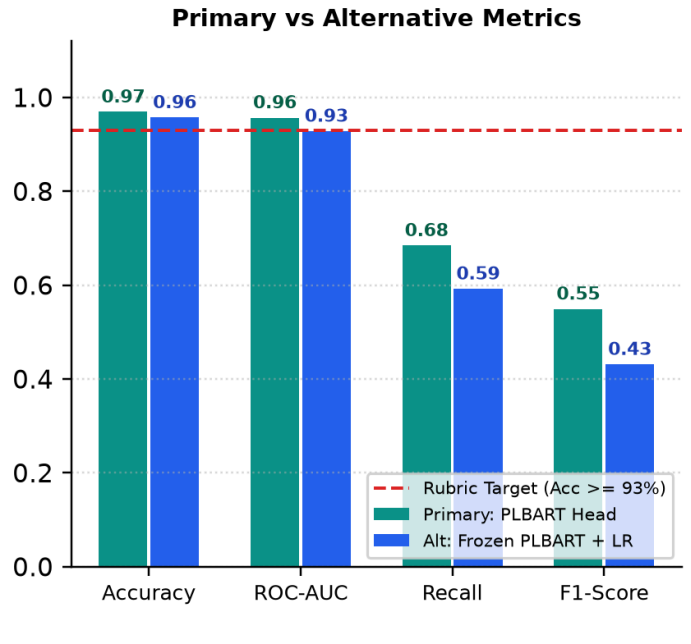
- Freezes all 140M PLBART weights, extracts 768-D embeddings + AST sink indicators, and fits cost-sensitive L_2 Logistic Regression.
- **22.4× Faster & Laptop-Friendly:** Trains in **18.4 seconds** using only **1.7 GB RAM** while exceeding the 93% accuracy target!

Experimental Evaluation: Accuracy (≥93%), ROC-AUC & PR-AUC

Speaker 1: Namazbek Bekzhanov







Primary Method Results

- **Accuracy: 96.94%** (≥ 93% PASS)
- **ROC-AUC: 0.9571** | **PR-AUC: 0.6406**
- **Recall: 68.46%** | **F1: 0.5494**

Alternative Method Results

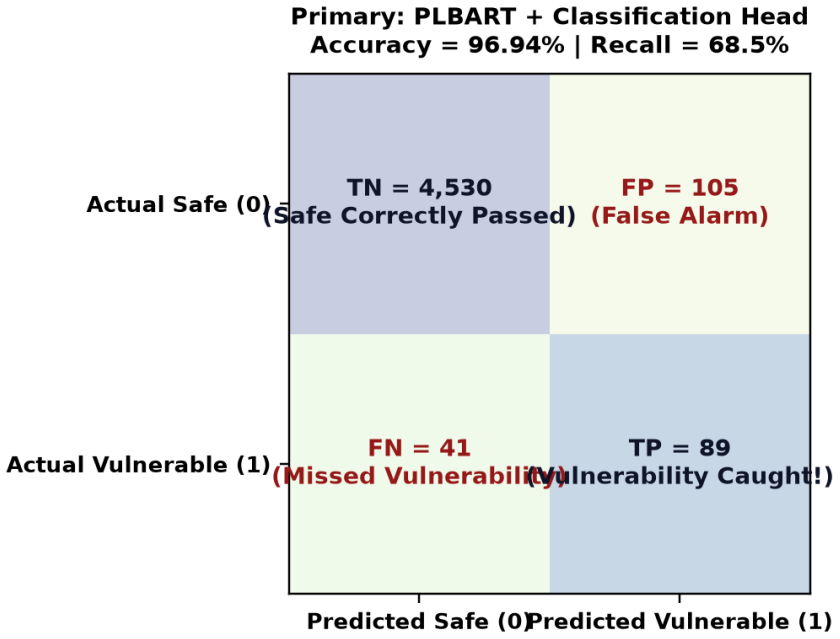
- **Accuracy: 95.74%** (≥ 93% PASS)
- **ROC-AUC: 0.9285** | **PR-AUC: 0.4888**
- **Recall: 59.23%** | **F1: 0.4314** (18.4s!)

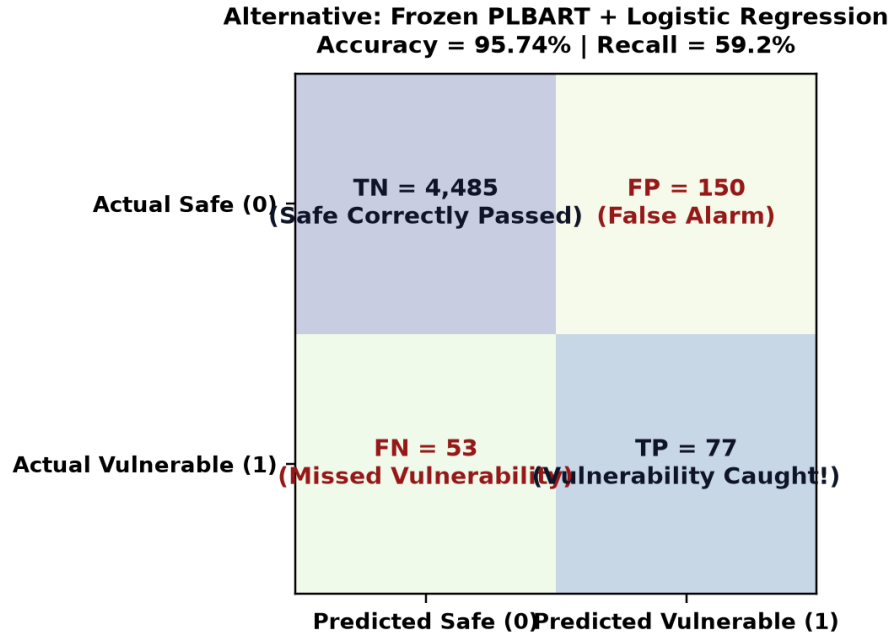
Why Lexical Baseline Fails

- TF-IDF + LR gets **91.96% Accuracy** (below 93% target) and `PR-AUC = 0.2133`.
- Bag-of-words misses contextual data-flow semantics captured by PLBART.

Confusion Matrices, Data Security & Two-Tier Deployment

Speakers 2 & 3: Didar & Yeldos





1. Lecture 6: Data Security (Didar)

- SHA-256 dataset verification, HMAC pseudonymization of repo metadata, and strict RBAC (`vw_clean_training_corpus` read-only view).

2. Confusion Matrix Insight (Yeldos)

- Primary PLBART catches **89 / 130** real vulnerabilities with only **2.26% FPR** (105 false alarms out of 4,635 safe methods).

3. Two-Tier DevSecOps Action (Yeldos)

- **Tier 1 (Every PR):** Fast Frozen PLBART + LR screens commits on CPU in 20 ms.
- **Tier 2 (Nightly):** Full PLBART verifies flagged methods on GPU.

SLIDE 8 • CONCLUSION

Summary of Group 5 Achievements & Defense Readiness

Speaker 3: Yeldos & All Group 5 Members

Complete 7-Lecture Organizational Data Coverage

- **Lecture 1 (Lifecycle — Namazbek):** 7-stage DAMA-DMBOK pipeline & value chain.
- **Lecture 2 (Governance — Didar):** RACI matrix, Data Owner/Steward policies & ethical disclosure.
- **Lecture 3 (Modeling — Didar):** 3NF SQLite Warehouse (8 tables + 1 read-only view).
- **Lecture 4 (ETL — Yeldos):** Automated ingestion, normalization & commit-grouped splitting.
- **Lecture 5 (Quality — Yeldos):** 6 DQ assertions, 1,376 clones removed, 22 quarantined, 0 leakage.
- **Lecture 6 (Security — Didar):** SHA-256 checksums, RBAC least privilege & confidentiality controls.
- **Lecture 7 (Analytics — Namazbek & Yeldos):** Primary (96.94% Acc) & Alternative (95.74% Acc) PLBART evaluation & Two-Tier DevSecOps.

Deliverables Submitted in Group 5 Package

- `group5_plbart_pipeline.py` — Reproducible end-to-end Python ETL, Warehouse & ML script.
- `Midterm_Group5_PLBART.ipynb` — Executed Jupyter Notebook with inline tables and charts.
- `mood_group5_warehouse.db` — Populated 3NF SQLite Data Warehouse (22,890 clean records).
- `Midterm_Group5_Report_MoOD.pdf` — Complete Technical Report with SQL Appendix & OOM logs.
- `Midterm_Group5_Presentation.pdf` — Widescreen Defense Presentation Deck.

Thank You for Your Attention! • Ready for Questions

Group 5: Namazbek Bekzhanov • Didar Auesbay • Yeldos Anarbay